

Rhysida Threat Profile

Date: February 26, 2026

Rhysida is a prominent Ransomware-as-a-Service (RaaS) group that first emerged in May 2023. Despite being a relatively new player in the cybercrime landscape, they quickly gained international notoriety for targeting high-profile organizations across various sectors, particularly healthcare, education, and government.

Here is a detailed breakdown of the group's operations, tactics, and history:

1. Modus Operandi

Rhysida follows the "**Double Extortion**" model, which has become the industry standard for sophisticated ransomware groups:

- **Data Theft:** They first exfiltrate sensitive files from the victim's network.
- **Encryption:** They then deploy ransomware to lock the victim's systems, appending the **.rhysida** extension to files.
- **The Leak Site:** If the victim refuses to pay, the group threatens to publish the stolen data on their dedicated Tor-based leak site. Uniquely, Rhysida often puts the stolen data up for **auction**, selling it to the highest bidder if the ransom isn't met.

2. Targeting Profile

Rhysida is "industry-agnostic" but has shown a preference for "big game hunting"—targeting organizations where downtime is critical. Key targets include:

- **Healthcare:** They have frequently attacked hospitals and clinics (e.g., Seattle Children's Hospital, Prospect Medical Holdings).
- **Education:** Schools and universities are common targets due to large amounts of personal data and often underfunded IT security.
- **Government & Defense:** They gained early fame by attacking the **Chilean Army** and later targeted several local government agencies worldwide.

3. Technical Tactics (TTPs)

The group uses a mix of modern and "living-off-the-land" techniques:

- **Initial Access:** They primarily gain entry via compromised credentials, RDP (Remote Desktop Protocol) exploits, or by exploiting known vulnerabilities in VPNs and firewalls (such as Citrix or Fortinet vulnerabilities).
- **Deployment:** They often use **PowerShell** scripts to terminate antivirus software and distribute the ransomware payload across the network.
- **Encryption Method:** The ransomware uses a combination of ChaCha20 and RSA-4096 algorithms.
- **Ransom Notes:** Unlike most groups that use plain text files (.txt), Rhysida typically drops their ransom notes as **PDF files**, which look like official documents from a "cybersecurity team" claiming they are there to help the victim identify security gaps.

4. Links to Other Groups

Security researchers (such as those from Check Point and Microsoft) have noted strong similarities between Rhysida and the **Vice Society** ransomware group.

- They share similar targeting patterns (heavy focus on education and healthcare).
- There is significant overlap in their technical infrastructure and the way they move laterally within a network.
- It is widely believed that Rhysida is either a rebrand of Vice Society or a spin-off group using similar developers.

5. Notable Attacks

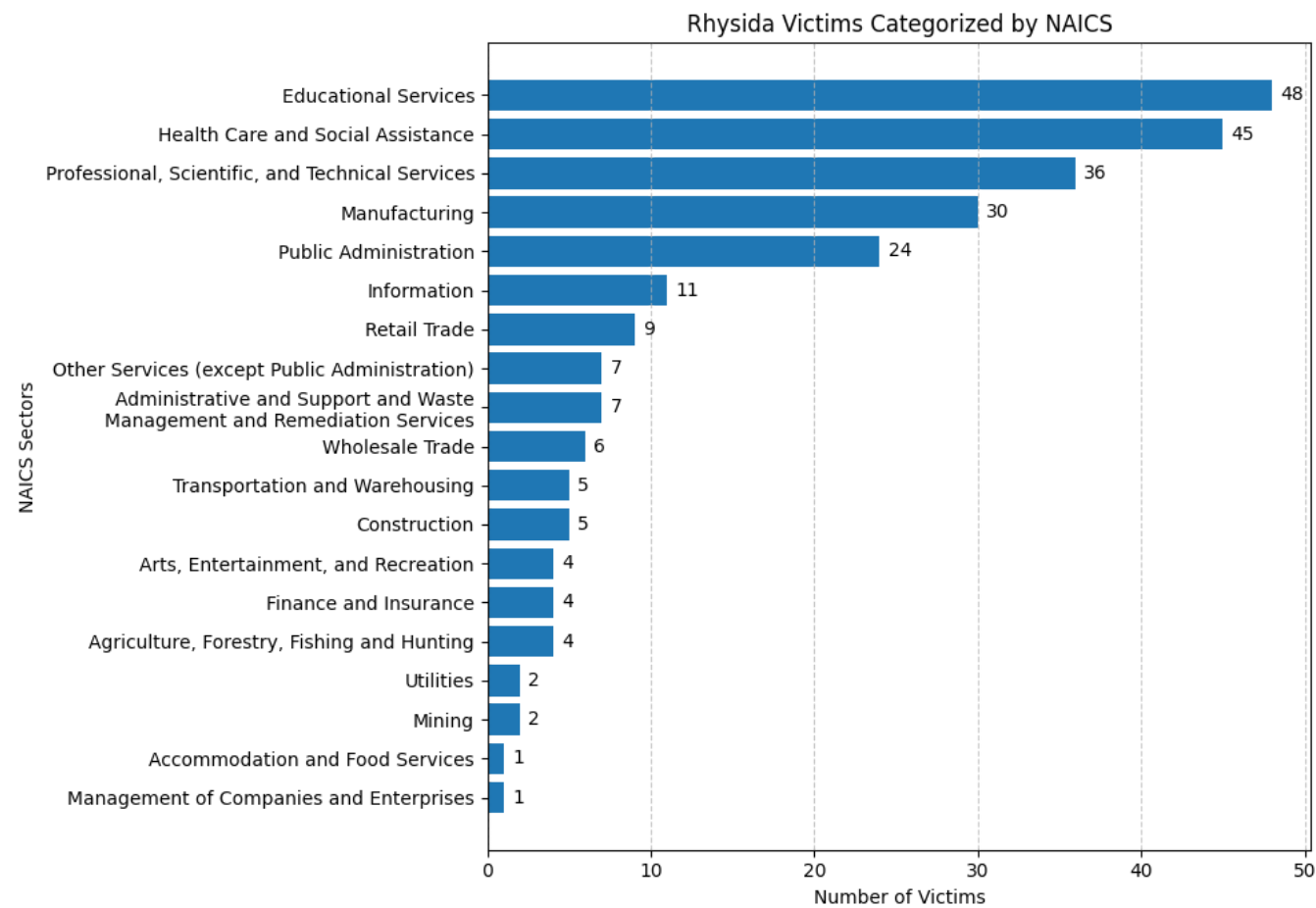
- **The British Library (2023):** One of their most high-profile hits. The attack caused months of digital disruption for the UK's national library and resulted in the leak of roughly 500,000 files, including employee data.
- **Insomniac Games (2023):** Rhysida stole over 1.6 terabytes of data from the Sony-owned game developer, including early gameplay footage of the upcoming *Wolverine* game and personal information of employees. They eventually leaked the data after a failed auction.
- **Chilean Army (Ejército de Chile):** This was one of their first major attacks (May 2023), signaling their capability to penetrate high-security government networks.

6. Summary for Defense

Rhysida is considered a sophisticated threat because of its speed and the "professional" nature of its extortion tactics. Cybersecurity agencies (like the FBI and CISA) have released advisories specifically for Rhysida, recommending:

- **Patching:** Prioritizing vulnerabilities in VPNs and edge devices.
- **MFA:** Implementing Multi-Factor Authentication across all services.
- **Backups:** Maintaining offline, encrypted backups to recover from the encryption phase without paying.

Industry Targeting



Malware

Name	
0	ransomware
1	OysterLoader
2	CleanUpLoader
3	Latrodectus
4	ChrGetPdsi
5	Rhysida
6	PortStarter

Indicators Valid Until June 14, 2026 03:31 AM UTC

Type		Name
0	SHA-256	a653b4f7f76ee8e6bd9ffa816c0a14dca2d591a84ee570d4b6245079064b5794
1	SHA-256	eef6d4b6bdf48a605cade0b517d5a51fc4f4570e505f3d8b9b66158902dcd4af
2	SHA-256	e9f05410293f97f20d528f1a4deddc5e95049ff1b0ec9de4bf3fd7f5b8687569

	Type	Name
3	SHA-256	80c8a6ecd5619d137aa57ddf252ab5dc9044266fca87f3e90c5b7f3664c5142f
4	SHA-256	3d22a974677164d6bd7166e521e96d07cd00c884b0aeacb5555505c6a62a1c26

Indicators Valid Until July 19, 2026 09:34 PM UTC

	Type	Name
0	SHA-256	d47f28bf33f5f6ee348f465aabbfff606a0feddb1fb4bd375b282ba1b818ce9a
1	SHA-256	9dc86863e3188912c3816e8ba21eda939107b8823f1afc190c466a7d5ca708d1
2	SHA-256	d46bd618ffe30edea56561462b50eb23feb4b253316e16008d99abb4b3d48a02
3	SHA-256	ac5065a351313cc522ab6004b98578a2704d2f636fc2ca78764ab239f4f594a3

Indicators Valid Until August 06, 2026 10:10 PM UTC

	Type	Name
0	SHA-256	87c787ea53a4dad92afd36c13a4fc5da7af1ea8dbe5634e4e3b011f289c9c91b
1	SHA-256	382af3f71da0480e279fc7be35159aba4cd0ff303672ac9b506031d0d0825b36
2	SHA-256	6147f86e79bdcbae37e724ada941c5129b8ef904fc9e3c498a3923c69937d99c
3	SHA-256	db3af674f9b85a916b48710c4b663b50ed324f67021fe3ca6ffee9a917c6f2bd
4	SHA-256	71fc456191dac6467fcb416b485396ae8995861e13694e7f1d022ac9631a3b54
5	SHA-256	fa3b9f050519f8106a424f92aab6a7714fefe36ca3b859acb099ae1467d8c0ae
6	SHA-256	392fca50afaf4a2d5246f865bd9be49722d257f60e08a70997ababaacccfb836
7	SHA-256	5ef4165814a06f164cec6f6323d11bf62d7934a61c2b992fc47ca5319d3e9373
8	SHA-256	2c3624344070c78c0785b5e833c0d56a5cec3f5e58ce53b9c17018d9386b7f37
9	SHA-256	85ec3f2c2b15247fbcd4bb2c5a6029f9972f9f57481977750eba24d2974e4bac
10	SHA-256	987bfdf18e0b3dac53bcc8cc906ef6c907c3e23d9ff23eb703e196782ae00b00
11	SHA-256	7b40b2650636adbd94119dc131b42f9d74bcafd592ce8c6367a537438c2c4831
12	SHA-256	f1b27d88bdb6b4d2019191b539f130edceb6b7ec16bd4131159256b4c872a8fd
13	SHA-256	78e2cde1aa394ed90a172ac8adb3f0e8c6f0297607ad117977e3a4b112667ed3
14	SHA-256	dc25dd8cc1ce53da33777c82b6acfb820ede522e894093386349538e0b58d86c
15	SHA-256	dea85c1e75be9db2c7c96007283389ddf28a21d79a05f3e6396a0c7f780b7b9f
16	SHA-256	c74390fc167ddd3532d9484db4ef66ff49ae8accce98c5eeec7261c174a032db
17	SHA-256	f55df05f07ac4c0be0bcfd0815df4643ffc8aa3592253dbdbf110df978653542

	Type	Name
18	SHA-256	be5bcdfc0dbe204001b071e8270bd6856ce6841c43338d8db914e045147b0e77
19	SHA-256	f7dea7d5f87f19c73def52f3b40ca9f0c903a82d49fccb65d3acc1c4f12ad17c

Indicators Valid Until August 20, 2026 09:25 PM UTC

	Type	Name
0	SHA-256	910d5d87a5ca499523607e4a7455059e7bed48d5b9889a696f5c13fe0aa6fe60
1	SHA-256	dcd82f7f01855769e9a2dad934be7231d6a7c50254077c094f4c3324daeed715
2	SHA-256	0c89de2e1d6449ab5c192d383ebb2bfbb3df4fd6c1f2beaff9804b8e10cc0db0
3	SHA-256	88e9c1f5026834ebcdaed98f56d52b5f23547ac2c03aa43c5e50e7d8e1b82b3a
4	SHA-256	37d0bda4af155625931d030c23594d450a272549ddb32380d3c5ee94feb03a25
5	SHA-256	1c20550543d4bca865c92f66f4a10d6c2f5348d0638f93854a0ba6ae0715a37f
6	SHA-256	fad9aa1c52f3a9453bccb343626aa5cf3e37d09109bed07c20bf1dd3027088a5
7	SHA-256	b52dddf4022ee45243ad01705d5a8d5070cd62aa89174f1ab83f5b58f66d577a
8	SHA-256	49af54b21ac46de4d87b2c1067bf3f62d379800fb8616d0a4b3500ae7656ac71
9	SHA-256	6bfaa362a46f0c5e7b10f43575523628b36c69a1086c5acd1c512db5465ed12e
10	SHA-256	b0bed317b0288fdedc2f122876f37284d6f654c0fbedd525a0f396069a304e9e
11	SHA-256	328a8fb3ff41093c3b3352a6b3771e1d3351a04861ee73c7260ecb0e84aa51ff
12	SHA-256	9ac7c82eba9200fb11ac047bf259f30d4e6929e1f8a472557a3a81cdd1a492db
13	SHA-256	65d50bb63d3d0176059ec26a63cd781aad016202b51cb6e4477f36ca6d1e7f82
14	SHA-256	76b87bf2b60a62af93b9a711e59d90dfbd871c3c86f2740336b802b5db6a9f7f
15	SHA-256	2f9f61ceaf909adfa0cee2c4d30cda175609819bc10ece8776e2d69e11097076
16	SHA-256	c41f42e11e699f45a77ac4e8aef455a07b052180863748f96589d45525e250f6
17	SHA-256	118cc1823919d3aee728d206185cda96de4f59331d3eab2665d6a0ad8d7b85ff
18	SHA-256	2da601e17b8121d9c60c244c696c25d31aef6cb2b048a936138388afa32d5d63
19	SHA-256	de33a49ea5e783f82443e4fdd79a82917df0b67b3365f63172e117efbc8afd3a
20	SHA-256	67c668d317076373447e8354a648c612043a667204889ca6e4cc10f8463f6684
21	SHA-256	067f6c9d36af9d3c088a37151721eb4981dde65c549d22b5a3ada0b90441e571
22	SHA-256	9c71b13284540257ea41e3746cb230cee5a57f2d300ac78ff3f54efa41e7c71b
23	SHA-256	9ceb03fa1f0fc5084b856c4e099cb8391eef74b9ce1d1278bf01908469f7de7c
24	SHA-256	ba688e06db97044e50632f4cfce8f6206ba47353a21bc33d5e93620baa6ace81

	Type	Name
25	SHA-256	d32b4924143948935a74f03ae921a4c2efa4a94848d49274208e7007c0102f73
26	SHA-256	c036e6d3d4cda6b936f6cbb06bc7cc83491fbbfc6df8b67bbcb3140c3a22d8a5
27	SHA-256	18b680773fb2b58e34166c7694dd9f533e66936d6effa2430d7c7fbaa57e8722
28	SHA-256	a18489fcf785fff454dc2df15ca8e4b6b411de2505ffb732e8100ad9f87bf722
29	SHA-256	75a83017f6d55223d90188f05a3efd9d4c19fe2c3e0cd0a17d4bd1e6375592f1
30	SHA-256	f994a1ba402bc29ac7f770d5d11772de6e2575895f50850d7ee9808c484dadcd
31	SHA-256	32b0f69e2d046cb835060751fcda28b633cbbd964e6e54dbbc1482fff4d51b57
32	SHA-256	920b4a80e1d5723dd255619ea05788a5ab7fff420fed86e636307c38fc2c8093
33	SHA-256	b61b51ba6ad7f7fe6465093a7c3f3f10d1079159febe33efb26fd64fa80408f1
34	SHA-256	167405ea2fcbf5e6634bc2562872493d035941a7b93194b58f5a60053f1fba86
35	SHA-256	401e3fe6d27a438016a82c4bbc710dfca5ff3c8f533f5eadc7393ce4f1c2d498
36	SHA-256	2a70db4e14fca6d80ce90c21954323299f8c32bc6fabd67744896af4ee8809b7
37	SHA-256	70f12e989284b2f2909e2df05e8e82ab1720ddb1e832b9abdf2ae541ac3048d6
38	SHA-256	8c9dd760471ebe024ffff773d6ab71a6c593596666d58a9ac4f770fa04b9f9e
39	SHA-256	6b36a472b274661d11f93f4d7dadafad2416f6d633a151d473b73cf4035f6a01
40	SHA-256	0a0b5a41127b8a33da8142b9fe055caa42634247501d7157c9432cce612f7392
41	SHA-256	d668fd0963491a27dcd57980fe42eef14d202f7299863cc1f264dceceab203bf
42	SHA-256	e393249cf381a0516aa10d9a8f6c2ae5ed6f6aee438da3b3d956dbb09fbc91bd
43	SHA-256	bd6ad2e1b62b2d0994adf322011f2a3afbb14f097efa3cbe741bc4c963e48889
44	SHA-256	6e937cf174aafb9c97ffb1e04eb11a59406a55cb8bc217e46837e45ba08763be
45	SHA-256	378127a840393f72bc2e98a1a3f54a57d05c08650dd485183a5554f0658632a8
46	SHA-256	950c4a7eba7fc1b1555f94ba696a792df45145313c71993eaed30f339576ebbd
47	SHA-256	fa48ee3e0cd60dc00ecda22b6136d5312bf207bc3bfa88430230483d10e73f9a
48	SHA-256	b2fb041a0f642f624a99ac5509b1008f18d8aedb74a9753f26d577ba99914c6e
49	SHA-256	d2d6c8e73ac2fa79597f47453e7f0a135eafdda26683b0a67bafabeaa2f9d495
50	SHA-256	d19a497670314a3bbff5bc958db3eacfe591c04f866f779cbc06e0f0f48b991f
51	SHA-256	251eadf6b434016cf30dfa4749762ef4c8ae1ec3255ac42f5b5f714750b1a49d
52	SHA-256	99f94e85906c99a44f3bdaf3750eb2870f082afba32f94899438f00fa85a5e92
53	SHA-256	593e272ecd0642a19ea21b086b494ac4e9098e6ff585b00b5b98b5ab0dd5b21a
54	SHA-256	b21feb4af9562de182710e13f91b10c0a1d0305e126da6beac57a2b0e3a4308d

	Type	Name
55	SHA-256	823d5f021eab4e91a7d592931ef57d8382871e7dad92d4fafb826f0d4051f9e3
56	SHA-256	16474e9e4773fbc1e0b48a5025fad31b7f084b1beffb9a42687b4d01979885fe
57	SHA-256	0beda01f7eeafa049c2c1e655adbf94c8ddea15ab42b0262a838bb3d7bbe156d
58	SHA-256	464db7461d6d67d99132eeaa9962d3691a3efc73f194fb660b4b8c77c10d9591
59	SHA-256	512a7207048876f3d3edb588847bce9beee620675dd2a280a0efd4f08b0550d6
60	SHA-256	ed68817d107f411686943f182c5422070287d81dab6763802a5915110de01da6
61	SHA-256	0b0263cc504be6368ebee03d960251ecd844fa0fce9c989d7f4324d3fdf3ac9b
62	SHA-256	a3b858014d60eaa5b356b7e707a263d98b111b53835ae326cd4e0fb19e7f5b35
63	SHA-256	455979f3887f9ce119d56291df97dd71a3760676b498689e68495f329489e886
64	SHA-256	90fec9c7fd0111679d72970a15c520d49e8bb8edd108d5d74bc2bb24a055c126
65	SHA-256	b289560c80e340f5d18b30313cd40caac409ce42dbb224f14baa20faf89c6d06
66	SHA-256	031d6eb41d71750ead420f8172aacd0124cc8e6d5f2cbb8a6b38b71f06305b1e
67	SHA-256	0218c4c054ca7393b2df1a4029e839828aa014c1f1d0a1ad7bf2a516a86fc889
68	SHA-256	47664ebbec8945fa44458cd3cb232d6d961fe8367360d7d6a426ca0adaacbd15
69	SHA-256	ed37ed84f20fc4555128db196ac72402a6ebf4ba5b975fc3fafa1e80a629987a
70	SHA-256	44a26915bfe1a0f2823d81c08e9d9a96aab65ca73fa9186d09781b2a447e77b6
71	SHA-256	e25db8020f7fcadaec5dd54dd7364d8eaa9efd8755fb91a357f3d29bf2d9fbad
72	SHA-256	007a1b138c80f08aa1736f5d622e6dc4bd1da6c3dfb4bd81312ac3def3457006
73	SHA-256	10910179af37ba38786f5a1b59d4dd1c43b6aa512850bbd47fb0feb965b2eb5c
74	SHA-256	5a416afcb1f459e25c02aa5495298ced3b2db330e1a04960dd456fb968b0d459
75	SHA-256	7e6dfef5e87453cb9999e592d76f8b5ba4bb4d0e5c6eeb6f12de03fa17801a47
76	SHA-256	c5551ad82db5fb10fd0af5bfd272bc8e0a23b9f622b0421d235a90925793f064
77	SHA-256	d6d859b3b9461b96c26e5d0ba3e2d9bcbdb3827aff952258a6f695b3d98fd86e0
78	SHA-256	0b73e5fd2ccaac44e0c489187b1245bf233ec276c45043813e5da4fa07de13e4
79	SHA-256	0bd24cc34dc7d003c276f95771fb54429a5cebd6d5f9cabce7902a16b972b44c
80	SHA-256	61b5c52d4771029eb8c2d3457fd4e9118ad8cf5b02fc792fc4efb81543942d8a
81	SHA-256	3654c9585f3e86fe347b078cf44a35b6f8deb1516cdcd84e19bf3965ca86a95b
82	SHA-256	dcaed940e8f38d862b4d3262431dbfab9bf2cf9615243f4245eb4841d40aeebf
83	SHA-256	cd671cfa42714a6d517476add60690081a16a5c6abaacce25fcb9c5ddf41b7d3
84	SHA-256	89ac3ba2bb3811358ecdffbcdd3cac4c4bca9e7c2bd65303e3d9c338aa0b8888

	Type	Name
85	SHA-256	b0b384818cb093d0324c4676faf163aee95be6639399ad2e6bc805d4ba9d0856
86	SHA-256	bed5b5fc062b0f6ee73166818978dc533ce621066172ec5eecb183ad2e0a0ef3
87	SHA-256	32d8e4285515e9926da32796f3f8d743db7a410d0758e1237bd750428389ae23
88	SHA-256	09a25de9db895d3f49c285485fd7ce14fa547ad6601e2dcf9aff47d75b147ad0
89	SHA-256	2522ff78df91e93e1fbf08b9e0b820ca2d187aecdf9f6f68e83ae998ccfebc0a
90	SHA-256	8339392bded530e54115016e1a78b2f692a9c15a42f5f9c956de51f3f4aa1278
91	SHA-256	ada8654dcc9b01811e2e902e857d2b1960b5b58ac4f86b0b67147f5d8c6ca3a5
92	SHA-256	29777478e8c36226d1ec755d34c0553976b39dce3f209a766a5a41287749de0f
93	SHA-256	3826898251b22807fc011e04f2f6d88976a2d3699ac1ecbe5e5fff63c25b43f4
94	SHA-256	5968beab954b01ae92d3ae0af52606da5e7dbfddc23783de51089871d51f5f6f
95	SHA-256	eb56b8c537a20ffcefa4140ab30a2b6ee009c531c6c9748935574b7b3d7f41b0
96	SHA-256	3cfe02c2ed86c9a68c60113a531700a93bcd7364026e954793fb04768aaa4b6c
97	SHA-256	fb7dd033eafb8f2c16542755b7e629bbc7959ce223d3948478ea1dbc85de8844
98	SHA-256	a240be5b9acf1b32643347496d51b1ff3dabfcd4a6d7bd6bd43735ef3fdb6477
99	SHA-256	280ac27b98ee1a6dc078bbc3554dd812b71cc84b58e5459ee80d1e7919979754
100	SHA-256	009599a28aaf2a5f19d51489050d78f1e1510aa7f247a095222f80658f1f3777
101	SHA-256	2528df60e55f210a6396dd7740d76afe30d5e9e8684a5b8a02a63bdcb5041bfc
102	SHA-256	b41e0c36f941fb3bf2fcb3e9a336240dab2c1184b5b28d2a52369cd80be5c974
103	SHA-256	623cf7b5a12c9e2a54f6d1ea2162371cdfba23806d443f2dc55aed1d7f2d9077
104	SHA-256	64a0ab00d90682b1807c5d7da1a4ae67cde4c5757fc7d995d8f126f0ec8ae983
105	SHA-256	38040afcce0e490d76c3be336a4754fed3095d075b22753e3f93004ddb45eef9
106	SHA-256	3a5e4bc5239f76e4bbb39515b50a2be61177e1a668ee6c49d01bfba6887abdc1
107	SHA-256	8703dad18a0c3a3759850c468c768e9b704f9299c16ea2ad3851ba399b5cf5d0
108	SHA-256	5c797080fa605cab2cd581645f00843f9c91c9c2d0ad4598ccb7886f990c916b
109	SHA-256	9ce7fa41d8088472dcda120012d025f16c638c57511ac4b337f16893c4580105
110	SHA-256	f70bbef58a5dfb9d4fb5ca114fd9a63a4443dccc59187ae4f3a28031b97cd85
111	SHA-256	c3dc4aa8991f1e257d4cce5338c2798b91f3a3eb576c627f866028106e7526b4
112	SHA-256	dcdbcba9c56a123c2a494e23521ef80eb6cd69ba3b53d10f06b04cdc9477e2ed
113	SHA-256	8f97cf05cb9bc42e20b8ebabb743060b37b9ce1142531a0f74f21c23d7208344
114	SHA-256	fe64f1f91c70de3d20503d70c30072b42a13b3feb3cba961c0892026ac9c17a9

	Type	Name
115	SHA-256	10d25e100989504386b0c45dd2e563441f5b4abbc51e7df7f20bbce88132c71a
116	SHA-256	5ca57caeb3808e338d05bfd336c5ea582e3881c0976b5fb91f73bde13faba8a9
117	SHA-256	1806b6b144573eea34eb1835c16d514ebc5fd0b447cf957ad41d100ff91d8ec0
118	SHA-256	b4a4d565a4d69e1e54557044809fc281591cdc5781126f978df8094467ba59fd
119	SHA-256	169157f51c05aafda68eb367219a826ecdc90e941e4397da20021b0f4ee2ae14
120	SHA-256	91b0fddece24cd9a6a02184e1f1e1b484a2b63fbd647d10935b01a7f25ca8528
121	SHA-256	c8166ccb6734a53a45223fe6ecbfff80e713ebcb356a24b2709cf6be20e150ae8
122	SHA-256	a6b6b6d3404398f096963f60149d5c98409f3d565cb181bf285e7212323c646c
123	SHA-256	13b1d27bb1fa279da12934f1c219baf993b1170c57207d95c4a5aa258c402b6c
124	SHA-256	4c04ff5df6341af1e27d91a837c1749036c73723eb393383c3691bbbc16db5a3
125	SHA-256	0bcdbd79c13fc50955804d0f2666c878542157fc3d4987d18d13c72e9697209e
126	SHA-256	700d425033a588f6cf399bdaaa0e29694f54233380085225e38f9f1544dac316
127	SHA-256	315c072b30d77e1fc5aa61122e2bbbcdee0eab9942ee985d23615612809411c5
128	SHA-256	93c518eacce858d46c296f76ccd0e3fbf13f426f7d5b63320dc27987f8b1f4fc
129	SHA-256	98ecdcc1c1f723f38bbbb3f33d870dea34eae2e832a6a88618104406057da51
130	SHA-256	2f979fc96430123644fb216e2e6b7918804c6797d33cacaaaa4b861da150f801
131	SHA-256	31ebdf2d6fb973f648c05226b57ff264d8b650dfe03f995deba0fa795d76f37c
132	SHA-256	0f1dc290dc20f3eefb0f6cb4d965e437f207484151f57d0fe3b58b33565e99bc
133	SHA-256	a9522fbe86712f17679ad5d900408cb1258886896c219bd647253ef54c36648a
134	SHA-256	658d1e166dcc723974013f42121d5ad9365e5059851e9b7a5964c4d175a86377
135	SHA-256	1e4fc7c691cf4ea2e7860bb1496aed1a21ccf1feb4794367c78914d9882b800f
136	SHA-256	e3de506891264da9ef37f3c277aac590d1038c264805bd51e3fd9df8ff4b4050
137	SHA-256	76bad29eb451c1c19b2ea6c416ffd71de33e495965c83c00b1556ad79860b46d
138	SHA-256	4963e646f9a4dc009e1d0f49b212d380818be69ea631af53f54b5b877515b031
139	SHA-256	72bed9b26a7747252156b65d24a9a737d70b9bf6aca069c514c1c7b9e04ef9b6
140	SHA-256	c92081585c525afba5abcb773c7ca9532fba6ce5e7aca340a226e2b05ff3b0d2
141	SHA-256	71aa6bd5515fd2ed8ce7f6de0cbb9dfb9875fcc91ae4b06cfc30d6e9d244125a
142	SHA-256	e72755cc9530632feecb80c0c13d544de42569a9e8c9a4bbe989c68c43118608
143	SHA-256	da6fbd0983a51f8a5f00bbcb2e26f7cb4adee36fa515c7e8cf12b9b4ea3acdec
144	SHA-256	f21483536cbd1fa4f5cb1e996adbe6a82522ca90e14975f6172794995ed9e9a2

	Type	Name
145	SHA-256	c431436792ee701826dd1661e415ee4def0e8c81e71edd7500a6f0d45cdc935f
146	SHA-256	a3b7ad3ac10b437dbe004aa6ec90b480a14304f2d5c59b77cb8559e96e1a6841
147	SHA-256	6e160815c18c6b011a59101f15d00c8cf035bff1549ff6c4c70e1ec9826b51d4
148	SHA-256	2fe0bd27009fc17f5150257cf84a74429005f101744ca20a4ad599ed6e6869c1
149	SHA-256	0c129527ef42dfc540e69810b4335afe2969c194e0db7cffada2ad9118bf553c
150	SHA-256	7c88fc26ab4abd3798d8e0c1de7d2bb8f05d73ea2a209b443f01681b3cfc624c
151	SHA-256	51c85e40fb4f5bc3fd872261ffef181485791e2ffbe84ab96227461040a1ca4d
152	SHA-256	4e4a3751581252e210f6f45881d778d1f482146f92dc790504bfbcd2bdfa0129
153	SHA-256	59374a1831e3eeba4e7553828b06636058535a6b7fb0bf7d28abae42bf47c15b
154	SHA-256	414af9a01ad4aa98a4e9cb3056acfd26b3d67a40670d90a9d51916400f3b9b1
155	SHA-256	b339fed7fef43e82877fa606d19ae94b1393d75e09637066acc69777478a3799
156	SHA-256	9e89d9f820c118b446cc8cebc02c614442a858c80a5678920acf1dc898a1a6c0
157	SHA-256	c08d5d2647f298c493475fe5ad22b6e6e71f9cd5ee24ed0e62acf98eee119271
158	SHA-256	da9f5bc07713fb952904c262458f3aec1a7a85855acc0ec9a5295122a35757b0
159	SHA-256	07251b9dd774e7dc598899239701d289893bd36b1a464bb569bd7835b9d3cf25
160	SHA-256	32f886142de76f09b1e7229a79e66eb46889251ebf871e4df3b6de7fd5cef749
161	SHA-256	d60281b86c6061ee623b7b96de9cdf7c8886a09ef4ebc8f3f09cfbdb21788f88
162	SHA-256	9e2f77b3db4a2ba81b35d69ec759fbe881821916a6ea75fd817433d1bea05d1b
163	SHA-256	db16458f707d77cecc73c0f52db943bfd40970d9074f2d405e1fe1fd84fa5b32
164	SHA-256	956514e60299b120b91d97ae09ad2550cc62b568312a657ffffc3baea68491cf
165	SHA-256	79cbf3a8c78fd709a96a1a9b2041ff6cabb307149377996ff3b96ca74b6396c5
166	SHA-256	c66540bc726ae996fdc876819e41cdc0af4bdb092acb16ed5aefe031a3f20403
167	SHA-256	66f9b7151c90113d00480fa2038ac2bebf10c364f9bd72c7af87e73fb702fe34
168	SHA-256	21e5b23300ebfc4436d33223a3d1691dd4f188867acb754c29b3e06229b94ed3
169	SHA-256	bdcf136481e93e7773346c1dbff9dafaf295d85206437d767df8829ac0266e53
170	SHA-256	f9fe65a2938b3b36d619f2c6881ac509c4117ebada6c01fbd1585fc87522e6fe
171	SHA-256	f79ca66eba8c25d4e96b5afafbe1299c0d1e73816c6668df827776ad8362a5de
172	SHA-256	ce7996e11fba3009bfbbfa39ce99cf072f74e52e72ff0c297c741a26ba82bde5
173	SHA-256	e23ad69a19501fbd40a5319ce2b002272579831ee85922f6a08da85c6836915a
174	SHA-256	dae9df9ce0f5286cfe871fda680e4de440c8444a44ceb434c28d5ccf786f5e8d

	Type	Name
175	SHA-256	bfd8f9fa906e5c0162f20189584d97aa4557b40646474a2563df21b4a7adca2f
176	SHA-256	26639165495b51641e040e37ce62b94e220f3269f7f91de62d39ac5b101fa8ce
177	SHA-256	777bc86e3796d5d470950d84be16d51fd4e7b9c644cb95fd3db915fc53f5f80e
178	SHA-256	b659389cde06f5e01e592dca458fe1be07a302c40dc2a820c7f76d4ee788bad3
179	SHA-256	6772d49e6e3fa5e44f79ad5a4c9d16eda8946b7f2aded41afc939c52633c3eea
180	SHA-256	6f43cd3f05a27c95a9dd0f9550e53130dbce7be82b1451649ac7c02253c8d01e
181	SHA-256	c799ca5758b37776466fa3a95a9e2291c2b09273a31e5e91af7fc21c8bfc141c
182	SHA-256	1923d2bdeb9be4f3fb9e1a12dfbf60234b89d3861d6a8b7b0cd411419b7ab3d1
183	SHA-256	60e0a433c0114a628856f671e42d21f2e573b1b9b06ba545d77b8e2e12685a2f
184	SHA-256	3051f4843918b093df99429a9d84a8b9f285deaf767b6264f5cafaf40e2de53d
185	SHA-256	a0cd096c55a97b4c7782335bb4d4a14a47a910cbe55a5db7c666365237ab62f2
186	SHA-256	2b5fe2bd846cf7de739433f26cce2bbb8ecef71f095be3f8b6e059cdf53fab59
187	SHA-256	abb0e6628c891bcd8ed54bf08790718eeb0c7a44f157d28ced18adfebe4dce21
188	SHA-256	63f754cfa7d35fafc2b7d266dedc9b0e0ff9bdd26ded697d0103a165c57fb332
189	SHA-256	765816c6e2c600c379014b4923f3d05eff5e91f46712da0fb21de99a6ca68021
190	SHA-256	993c35592d2e24f4ffa7c5135bef3381c8c99267eeb8d9eb6024e98edb453181
191	SHA-256	7fd1251942a234fdce00670965d5f3b5161b3c74c3965c40035856879e268717
192	SHA-256	6190923b28679eb8230010aff9b1d1a4184e8697540cc021a5be38126f3f6d99
193	SHA-256	352d0c75c5bfa7c0df18837ba845f47689fe480ce1a36920298c230204025526
194	SHA-256	b51148194480762881da57fddb7f158ae9ffb5964a5e0f57a57922151296d1bf
195	SHA-256	f961943a6e1142a419ab779f8a0283309d9dab20f40cb2651eeb91932bfa34d9
196	SHA-256	3073e0b73031e1cd8cc6ea2fef729ff65b5d9695742a0686a87aa7a6864e9f2c
197	SHA-256	08c3ea261d7849bb91506dc111c348a6dde3bc6f35a95470e4d650bd3513c7c5
198	SHA-256	8b152e373d6beea6e48fe5d8f919dd2c8e5aa0ddd21c8e91f44811b32c0aee99
199	SHA-256	7d05d66447c03feefe7a3493218137b38a9915f66392873829afe6f5d218152e
200	SHA-256	6b3e43c17908ee10944c2453983444da0f0242eac47534d0fb6111a03df0c66c
201	SHA-256	d1855b064845c449eabacb2789f2822af7cabe921030c5da1389ca168c9f4998
202	SHA-256	a4e1c33b1280a0b2daab512b5a4cfdd775743a1980c9b63eb4bfb739356378ae
203	SHA-256	76889ef23dc327c0a63da2e296e079ce1f6844da185c3160402341557e6bccfa
204	SHA-256	28594f15029da89f36ac905664350834acb0211cb5455df5419080fcee535001

	Type	Name
205	SHA-256	7746be73ef46672cd2ecc850fb48606204ec99b1affbd0a4d09067aef72db2a8
206	SHA-256	096b28df3ec509beec0d6a91c48855204ef43d20488cfc436626ee3089a74e49
207	SHA-256	4926a7479d5802b57571624084d94a50e35e6fc357ff96e2c38d03528dfc58a7
208	SHA-256	dae7fd577ae78efb038ec5dcb732a544d4813b6b3182e82cf2a5d01933a29f64
209	SHA-256	3fc5cb5b0a4436d51736eb1dc36ff47bd6ce8966077adf909bed4c95435ab20a
210	SHA-256	a783f7aad42661ce2425cb50911448b55622477f4e8c0c93f6b0649a76d87c17
211	SHA-256	daaa1c9233a8690ded9f093d5a114f3bbaa92aad269d21d36cb15a442249b070
212	SHA-256	5d3040ceeb03c1cde7d1da81d6ed5523f056d2289efb99dd5350de4cf56b2bc8
213	SHA-256	8113fc3b4f82fb49f8dd853ca8e1275e0dfb06e48f39830708e4437fe8afbdfb
214	SHA-256	d207830298fda267c7ea01afe5b429453587729040f525875cdd36eb4e606dc7
215	SHA-256	99d4306711abda3bed21dd2bb16d0a8e316022b8eca2f56e2ba25b615794a487
216	SHA-256	d8db253683e711069ef60ea3c60ad23d4ff1bc5cb70eba7ac87fdbcdbdb83634a
217	SHA-256	f6ae12f9d02688598d5ee38b7656723521c49a89fb284347b407a0fd4f59befb
218	SHA-256	7c74d74c6d6a4ffc724a7800ddf18e165e582e2e4b0aace1b5266ec3d25a9775
219	SHA-256	24e7b7702b0b3536e0cfbaaf88cec3ccca35da6daa4c22d811d44077f05d27ec
220	SHA-256	a78d9be1dc0ad300aae19c3c1c4b443732adb621c674addea99c3c46ffffaa1c
221	SHA-256	0f680169d5eaab7cebda7b323c59518b31d70efe2a8a1b759f0698d5f918dd9d
222	SHA-256	9aa596a4abdc5b5b00f4100df28b2fdc634c725e4948f3f8605f9f09e447db6a
223	SHA-256	6c842bf4b20a67750ec5d6505a62f1533e56fa88f8fa14c10b1270b7b6184af9
224	SHA-256	59e47f0db72ce4dfe02eed7bddc0324d13f0762ad33f25fe40ef234f888a91ec
225	SHA-256	9135d8d30a0be1c26ad2730e440e66f29c36e47d866b40d5dfcbf77eb515eb25
226	SHA-256	eddc26773927d95ab78778a259279e668f52710844f7e3eb4fbdffb5552dc4f1
227	SHA-256	9cc65abf806c44ce3c2162d0e8538c6e2f669b6cb378a612a37058ca84b921f3
228	SHA-256	edfd6951dfcd90b2cd8df3b9ed4aa3be022969f8c70045f11ec1677ea7445006
229	SHA-256	fdfae96c3e943c16f7946d820598b2d205395fe7483b5b82e4a9903dc96c1eb1
230	SHA-256	4ddb9521976c04879613601ae1399b7b9809dcd33d58869b2a2053e716d35442
231	SHA-256	d0f732eb0dc281749c1b6fbf43897e67e136743357879f6375dc6fd510a1a214
232	SHA-256	184bcc026ef26fa97375a5013bc90e1b035fa7e21b2fd41ca220654087f1d96e
233	SHA-256	e8d5019707065a8c894faf2c08ae2595d6b12381f1a850bfe9c9d693a5a6a8df
234	SHA-256	2cb872e5478cd1efa00708c778148cf5dcc2fd6e77f39ab63d96a1fc1587647f

Attack Patterns

	Name	MITRE ID
0	Remote Access Tools	T1219
1	Process Injection	T1055
2	Spearphishing Link	T1566.002
3	Domains	T1583.001
4	Exploit Public-Facing Application	T1190
5	Malware	T1587.001
6	Scheduled Task/Job	T1053
7	Code Signing	T1553.002
8	Obfuscated Files or Information	T1027
9	Exploitation for Client Execution	T1203
10	Local Accounts	T1078.003
11	External Remote Services	T1133
12	Software Packing	T1027.002
13	Develop Capabilities	T1587
14	Valid Accounts	T1078
15	Scheduled Task	T1053.005
16	User Execution	T1204
17	Digital Certificates	T1588.004
18	PowerShell	T1059.001
19	Application Layer Protocol	T1071
20	Exploitation for Privilege Escalation	T1068
21	Deobfuscate/Decode Files or Information	T1140
22	Valid Accounts	T1078
23	Virtual Private Server	T1583.003
24	Command and Scripting Interpreter	T1059
25	Command and Scripting Interpreter	T1059
26	Boot or Logon Autostart Execution	T1547
27	Clipboard Data	T1115
28	Malicious File	T1204.002

	Name	MITRE ID
29	Inhibit System Recovery	T1490
30	OS Credential Dumping	T1003
31	Obtain Capabilities	T1588
32	Proxy	T1090
33	Server	T1583.004
34	Malicious Link	T1204.001
35	Create or Modify System Process	T1543
36	Phishing	T1566
37	Data Encrypted for Impact	T1486
38	Acquire Infrastructure	T1583
39	Exfiltration Over C2 Channel	T1041

Appendix

Attack Pattern Descriptions

Remote Access Tools - [T1219](#)

An adversary may use legitimate remote access tools to establish an interactive command and control channel within a network. Remote access tools create a session between two trusted hosts through a graphical interface, a command line interaction, a protocol tunnel via development or management software, or hardware-level access such as KVM (Keyboard, Video, Mouse) over IP solutions. Desktop support software (usually graphical interface) and remote management software (typically command line interface) allow a user to control a computer remotely as if they are a local user inheriting the user or software permissions. This software is commonly used for troubleshooting, software installation, and system management.(Citation: Symantec Living off the Land)(Citation: CrowdStrike 2015 Global Threat Report)(Citation: CrySyS Blog TeamSpy) Adversaries may similarly abuse response features included in EDR and other defensive tools that enable remote access.

Remote access tools may be installed and used post-compromise as an alternate communications channel for redundant access or to establish an interactive remote desktop session with the target system. It may also be used as a malware component to establish a reverse connection or back-connect to a service or adversary-controlled system.

Installation of many remote access tools may also include persistence (e.g., the software's installation routine creates a [Windows Service](#)). Remote access modules/features may also exist as part of otherwise existing software (e.g., Google Chrome's Remote Desktop).(Citation: Google Chrome Remote Desktop)(Citation: Chrome Remote Desktop)

Process Injection - [T1055](#)

Adversaries may inject code into processes in order to evade process-based defenses as well as possibly elevate privileges. Process injection is a method of executing arbitrary code in the address space of a separate live process. Running code in the context of another process may allow access to the process's memory, system/network resources, and possibly elevated privileges. Execution via process injection may also evade detection from security products since the execution is masked under a legitimate process.

There are many different ways to inject code into a process, many of which abuse legitimate functionalities. These implementations exist for every major OS but are typically platform specific.

More sophisticated samples may perform multiple process injections to segment modules and further evade detection, utilizing named pipes or other inter-process communication (IPC) mechanisms as a communication channel.

Spearphishing Link - T1566.002

Adversaries may send spearphishing emails with a malicious link in an attempt to gain access to victim systems. Spearphishing with a link is a specific variant of spearphishing. It is different from other forms of spearphishing in that it employs the use of links to download malware contained in email, instead of attaching malicious files to the email itself, to avoid defenses that may inspect email attachments. Spearphishing may also involve social engineering techniques, such as posing as a trusted source.

All forms of spearphishing are electronically delivered social engineering targeted at a specific individual, company, or industry. In this case, the malicious emails contain links. Generally, the links will be accompanied by social engineering text and require the user to actively click or copy and paste a URL into a browser, leveraging [User Execution](#). The visited website may compromise the web browser using an exploit, or the user will be prompted to download applications, documents, zip files, or even executables depending on the pretext for the email in the first place.

Adversaries may also include links that are intended to interact directly with an email reader, including embedded images intended to exploit the end system directly. Additionally, adversaries may use seemingly benign links that abuse special characters to mimic legitimate websites (known as an "IDN homograph attack").(Citation: CISA IDN ST05-016) URLs may also be obfuscated by taking advantage of quirks in the URL schema, such as the acceptance of integer- or hexadecimal-based hostname formats and the automatic discarding of text before an "@" symbol: for example, hxxp://google.com@1157586937.(Citation: Mandiant URL Obfuscation 2023)

Adversaries may also utilize links to perform consent phishing/spearphishing campaigns to [Steal Application Access Tokens](#) that grant immediate access to the victim environment. For example, a user may be lured into granting adversaries permissions/access via a malicious OAuth 2.0 request URL that when accepted by the user provide permissions/access for malicious applications.(Citation: Trend Micro Pawn Storm OAuth 2017) (Citation: Microsoft OAuth 2.0 Consent Phishing 2021) These stolen access tokens allow the adversary to perform various actions on behalf of the user via API calls.(Citation: Microsoft OAuth 2.0 Consent Phishing 2021)

Similarly, malicious links may also target device-based authorization, such as OAuth 2.0 device authorization grant flow which is typically used to authenticate devices without UIs/browsers. Known as "device code phishing," an adversary may send a link that directs the victim to a malicious authorization page where the user is tricked into entering a code/credentials that produces a device token.(Citation: SecureWorks Device

Code Phishing 2021)(Citation: Netskope Device Code Phishing 2021)(Citation: Optiv Device Code Phishing 2021)

Domains - T1583.001

Adversaries may acquire domains that can be used during targeting. Domain names are the human readable names used to represent one or more IP addresses. They can be purchased or, in some cases, acquired for free.

Adversaries may use acquired domains for a variety of purposes, including for [Phishing](#), [Drive-by Compromise](#), and Command and Control.(Citation: CISA MSS Sep 2020) Adversaries may choose domains that are similar to legitimate domains, including through use of homoglyphs or use of a different top-level domain (TLD).(Citation: FireEye APT28)(Citation: PaypalScam) Typosquatting may be used to aid in delivery of payloads via [Drive-by Compromise](#). Adversaries may also use internationalized domain names (IDNs) and different character sets (e.g. Cyrillic, Greek, etc.) to execute "IDN homograph attacks," creating visually similar lookalike domains used to deliver malware to victim machines.(Citation: CISA IDN ST05-016)(Citation: tt_httrack_fake_domains)(Citation: tt_obliqueRAT)(Citation: httrack_unhcr)(Citation: lazgroup_idn_phishing)

Different URIs/URLs may also be dynamically generated to uniquely serve malicious content to victims (including one-time, single use domain names).(Citation: iOS URL Scheme)(Citation: URI)(Citation: URI Use)(Citation: URI Unique)

Adversaries may also acquire and repurpose expired domains, which may be potentially already allowlisted/trusted by defenders based on an existing reputation/history.(Citation: Categorisation_not_boundary)(Citation: Domain_Steal_CC)(Citation: Redirectors_Domain_Fronting)(Citation: bypass_webproxy_filtering)

Domain registrars each maintain a publicly viewable database that displays contact information for every registered domain. Private WHOIS services display alternative information, such as their own company data, rather than the owner of the domain. Adversaries may use such private WHOIS services to obscure information about who owns a purchased domain. Adversaries may further interrupt efforts to track their infrastructure by using varied registration information and purchasing domains with different domain registrars.(Citation: Mandiant APT1)

In addition to legitimately purchasing a domain, an adversary may register a new domain in a compromised environment. For example, in AWS environments, adversaries may leverage the Route53 domain service to register a domain and create hosted zones pointing to resources of the threat actor's choosing.(Citation: Invictus IR DangerDev 2024)

Exploit Public-Facing Application - T1190

Adversaries may attempt to exploit a weakness in an Internet-facing host or system to initially access a network. The weakness in the system can be a software bug, a temporary glitch, or a misconfiguration.

Exploited applications are often websites/web servers, but can also include databases (like SQL), standard services (like SMB or SSH), network device administration and management protocols (like SNMP and Smart Install), and any other system with Internet-accessible open sockets.(Citation: NVD CVE-2016-6662)(Citation: CIS Multiple SMB Vulnerabilities)(Citation: US-CERT TA18-106A Network Infrastructure Devices 2018)(Citation: Cisco Blog Legacy Device Attacks)(Citation: NVD CVE-2014-7169) On ESXi infrastructure, adversaries may

exploit exposed OpenSLP services; they may alternatively exploit exposed VMware vCenter servers.(Citation: Recorded Future ESXiArgs Ransomware 2023)(Citation: Ars Technica VMWare Code Execution Vulnerability 2021) Depending on the flaw being exploited, this may also involve [Exploitation for Defense Evasion](#) or [Exploitation for Client Execution](#).

If an application is hosted on cloud-based infrastructure and/or is containerized, then exploiting it may lead to compromise of the underlying instance or container. This can allow an adversary a path to access the cloud or container APIs (e.g., via the [Cloud Instance Metadata API](#)), exploit container host access via [Escape to Host](#), or take advantage of weak identity and access management policies.

Adversaries may also exploit edge network infrastructure and related appliances, specifically targeting devices that do not support robust host-based defenses.(Citation: Mandiant Fortinet Zero Day)(Citation: Wired Russia Cyberwar)

For websites and databases, the OWASP top 10 and CWE top 25 highlight the most common web-based vulnerabilities.(Citation: OWASP Top 10)(Citation: CWE top 25)

Malware - T1587.001

Adversaries may develop malware and malware components that can be used during targeting. Building malicious software can include the development of payloads, droppers, post-compromise tools, backdoors (including backdoored images), packers, C2 protocols, and the creation of infected removable media.

Adversaries may develop malware to support their operations, creating a means for maintaining control of remote machines, evading defenses, and executing post-compromise behaviors.(Citation: Mandiant APT1) (Citation: Kaspersky Sofacy)(Citation: ActiveMalwareEnergy)(Citation: FBI Flash FIN7 USB)

During malware development, adversaries may intentionally include indicators aligned with other known actors in order to mislead attribution by defenders.(Citation: Olympic Destroyer)(Citation: Risky Bulletin Threat actor impersonates FSB APT)(Citation: GamaCopy organization)

As with legitimate development efforts, different skill sets may be required for developing malware. The skills needed may be located in-house, or may need to be contracted out. Use of a contractor may be considered an extension of that adversary's malware development capabilities, provided the adversary plays a role in shaping requirements and maintains a degree of exclusivity to the malware.

Some aspects of malware development, such as C2 protocol development, may require adversaries to obtain additional infrastructure. For example, malware developed that will communicate with Twitter for C2, may require use of [Web Services](#).(Citation: FireEye APT29)

Scheduled Task/Job - T1053

Adversaries may abuse task scheduling functionality to facilitate initial or recurring execution of malicious code. Utilities exist within all major operating systems to schedule programs or scripts to be executed at a specified date and time. A task can also be scheduled on a remote system, provided the proper authentication is met (ex: RPC and file and printer sharing in Windows environments). Scheduling a task on a remote system typically may require being a member of an admin or otherwise privileged group on the remote system. (Citation: TechNet Task Scheduler Security)

Adversaries may use task scheduling to execute programs at system startup or on a scheduled basis for persistence. These mechanisms can also be abused to run a process under the context of a specified account (such as one with elevated permissions/privileges). Similar to [System Binary Proxy Execution](#), adversaries have also abused task scheduling to potentially mask one-time execution under a trusted system process.(Citation: ProofPoint Serpent)

Code Signing - T1553.002

Adversaries may create, acquire, or steal code signing materials to sign their malware or tools. Code signing provides a level of authenticity on a binary from the developer and a guarantee that the binary has not been tampered with. (Citation: Wikipedia Code Signing) The certificates used during an operation may be created, acquired, or stolen by the adversary. (Citation: Securelist Digital Certificates) (Citation: Symantec Digital Certificates) Unlike [Invalid Code Signature](#), this activity will result in a valid signature.

Code signing to verify software on first run can be used on modern Windows and macOS systems. It is not used on Linux due to the decentralized nature of the platform. (Citation: Wikipedia Code Signing)(Citation: EclecticLightCheckonEXECodeSigning)

Code signing certificates may be used to bypass security policies that require signed code to execute on a system.

Obfuscated Files or Information - T1027

Adversaries may attempt to make an executable or file difficult to discover or analyze by encrypting, encoding, or otherwise obfuscating its contents on the system or in transit. This is common behavior that can be used across different platforms and the network to evade defenses.

Payloads may be compressed, archived, or encrypted in order to avoid detection. These payloads may be used during Initial Access or later to mitigate detection. Sometimes a user's action may be required to open and [Deobfuscate/Decode Files or Information](#) for [User Execution](#). The user may also be required to input a password to open a password protected compressed/encrypted file that was provided by the adversary. (Citation: Volexity PowerDuke November 2016) Adversaries may also use compressed or archived scripts, such as JavaScript.

Portions of files can also be encoded to hide the plain-text strings that would otherwise help defenders with discovery. (Citation: Linux/Cdorked.A We Live Security Analysis) Payloads may also be split into separate, seemingly benign files that only reveal malicious functionality when reassembled. (Citation: Carbon Black Obfuscation Sept 2016)

Adversaries may also abuse [Command Obfuscation](#) to obscure commands executed from payloads or directly via [Command and Scripting Interpreter](#). Environment variables, aliases, characters, and other platform/language specific semantics can be used to evade signature based detections and application control mechanisms. (Citation: FireEye Obfuscation June 2017) (Citation: FireEye Revoke-Obfuscation July 2017)(Citation: PaloAlto EncodedCommand March 2017)

Exploitation for Client Execution - T1203

Adversaries may exploit software vulnerabilities in client applications to execute code. Vulnerabilities can exist in software due to unsecure coding practices that can lead to unanticipated behavior. Adversaries can take

advantage of certain vulnerabilities through targeted exploitation for the purpose of arbitrary code execution. Oftentimes the most valuable exploits to an offensive toolkit are those that can be used to obtain code execution on a remote system because they can be used to gain access to that system. Users will expect to see files related to the applications they commonly used to do work, so they are a useful target for exploit research and development because of their high utility.

Several types exist:

Browser-based Exploitation

Web browsers are a common target through [Drive-by Compromise](#) and [Spearphishing Link](#). Endpoint systems may be compromised through normal web browsing or from certain users being targeted by links in spearphishing emails to adversary controlled sites used to exploit the web browser. These often do not require an action by the user for the exploit to be executed.

Office Applications

Common office and productivity applications such as Microsoft Office are also targeted through [Phishing](#). Malicious files will be transmitted directly as attachments or through links to download them. These require the user to open the document or file for the exploit to run.

Common Third-party Applications

Other applications that are commonly seen or are part of the software deployed in a target network may also be used for exploitation. Applications such as Adobe Reader and Flash, which are common in enterprise environments, have been routinely targeted by adversaries attempting to gain access to systems. Depending on the software and nature of the vulnerability, some may be exploited in the browser or require the user to open a file. For instance, some Flash exploits have been delivered as objects within Microsoft Office documents.

Local Accounts - T1078.003

Adversaries may obtain and abuse credentials of a local account as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion. Local accounts are those configured by an organization for use by users, remote support, services, or for administration on a single system or service.

Local Accounts may also be abused to elevate privileges and harvest credentials through [OS Credential Dumping](#). Password reuse may allow the abuse of local accounts across a set of machines on a network for the purposes of Privilege Escalation and Lateral Movement.

External Remote Services - T1133

Adversaries may leverage external-facing remote services to initially access and/or persist within a network. Remote services such as VPNs, Citrix, and other access mechanisms allow users to connect to internal enterprise network resources from external locations. There are often remote service gateways that manage connections and credential authentication for these services. Services such as [Windows Remote Management](#) and [VNC](#) can also be used externally.(Citation: MacOS VNC software for Remote Desktop)

Access to [Valid Accounts](#) to use the service is often a requirement, which could be obtained through credential pharming or by obtaining the credentials from users after compromising the enterprise network.

(Citation: Volexity Virtual Private Keylogging) Access to remote services may be used as a redundant or persistent access mechanism during an operation.

Access may also be gained through an exposed service that doesn't require authentication. In containerized environments, this may include an exposed Docker API, Kubernetes API server, kubelet, or web application such as the Kubernetes dashboard.(Citation: Trend Micro Exposed Docker Server)(Citation: Unit 42 Hildegard Malware)

Adversaries may also establish persistence on network by configuring a Tor hidden service on a compromised system. Adversaries may utilize the tool [ShadowLink](#) to facilitate the installation and configuration of the Tor hidden service. Tor hidden service is then accessible via the Tor network because [ShadowLink](#) sets up a .onion address on the compromised system. [ShadowLink](#) may be used to forward any inbound connections to RDP, allowing the adversaries to have remote access.(Citation: The BadPilot campaign) Adversaries may get [ShadowLink](#) to persist on a system by masquerading it as an MS Defender application.(Citation: Russian threat actors dig in, prepare to seize on war fatigue)

Software Packing - T1027.002

Adversaries may perform software packing or virtual machine software protection to conceal their code. Software packing is a method of compressing or encrypting an executable. Packing an executable changes the file signature in an attempt to avoid signature-based detection. Most decompression techniques decompress the executable code in memory. Virtual machine software protection translates an executable's original code into a special format that only a special virtual machine can run. A virtual machine is then called to run this code.(Citation: ESET FinFisher Jan 2018)

Utilities used to perform software packing are called packers. Example packers are MPRESS and UPX. A more comprehensive list of known packers is available, but adversaries may create their own packing techniques that do not leave the same artifacts as well-known packers to evade defenses.(Citation: Awesome Executable Packing)

Develop Capabilities - T1587

Adversaries may build capabilities that can be used during targeting. Rather than purchasing, freely downloading, or stealing capabilities, adversaries may develop their own capabilities in-house. This is the process of identifying development requirements and building solutions such as malware, exploits, and self-signed certificates. Adversaries may develop capabilities to support their operations throughout numerous phases of the adversary lifecycle.(Citation: Mandiant APT1)(Citation: Kaspersky Sofacy)(Citation: Bitdefender StrongPity June 2020)(Citation: Talos Promethium June 2020)

As with legitimate development efforts, different skill sets may be required for developing capabilities. The skills needed may be located in-house, or may need to be contracted out. Use of a contractor may be considered an extension of that adversary's development capabilities, provided the adversary plays a role in shaping requirements and maintains a degree of exclusivity to the capability.

Valid Accounts - T1078

Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion. Compromised credentials may be used to bypass access controls placed on various resources on systems within the network and may even be used for persistent

access to remote systems and externally available services, such as VPNs, Outlook Web Access, network devices, and remote desktop.(Citation: volexity_0day_sophos_FW) Compromised credentials may also grant an adversary increased privilege to specific systems or access to restricted areas of the network. Adversaries may choose not to use malware or tools in conjunction with the legitimate access those credentials provide to make it harder to detect their presence.

In some cases, adversaries may abuse inactive accounts: for example, those belonging to individuals who are no longer part of an organization. Using these accounts may allow the adversary to evade detection, as the original account user will not be present to identify any anomalous activity taking place on their account. (Citation: CISA MFA PrintNightmare)

The overlap of permissions for local, domain, and cloud accounts across a network of systems is of concern because the adversary may be able to pivot across accounts and systems to reach a high level of access (i.e., domain or enterprise administrator) to bypass access controls set within the enterprise.(Citation: TechNet Credential Theft)

Scheduled Task - T1053.005

Adversaries may abuse the Windows Task Scheduler to perform task scheduling for initial or recurring execution of malicious code. There are multiple ways to access the Task Scheduler in Windows. The [schtasks](#) utility can be run directly on the command line, or the Task Scheduler can be opened through the GUI within the Administrator Tools section of the Control Panel.(Citation: Stack Overflow) In some cases, adversaries have used a .NET wrapper for the Windows Task Scheduler, and alternatively, adversaries have used the Windows netapi32 library and [Windows Management Instrumentation](#) (WMI) to create a scheduled task. Adversaries may also utilize the Powershell Cmdlet [Invoke-CimMethod](#), which leverages WMI class [PS_ScheduledTask](#) to create a scheduled task via an XML path.(Citation: Red Canary - Atomic Red Team)

An adversary may use Windows Task Scheduler to execute programs at system startup or on a scheduled basis for persistence. The Windows Task Scheduler can also be abused to conduct remote Execution as part of Lateral Movement and/or to run a process under the context of a specified account (such as SYSTEM). Similar to [System Binary Proxy Execution](#), adversaries have also abused the Windows Task Scheduler to potentially mask one-time execution under signed/trusted system processes.(Citation: ProofPoint Serpent)

Adversaries may also create "hidden" scheduled tasks (i.e. [Hide Artifacts](#)) that may not be visible to defender tools and manual queries used to enumerate tasks. Specifically, an adversary may hide a task from [schtasks /query](#) and the Task Scheduler by deleting the associated Security Descriptor (SD) registry value (where deletion of this value must be completed using SYSTEM permissions).(Citation: SigmaHQ)(Citation: Tarrask scheduled task) Adversaries may also employ alternate methods to hide tasks, such as altering the metadata (e.g., [Index](#) value) within associated registry keys.(Citation: Defending Against Scheduled Task Attacks in Windows Environments)

User Execution - T1204

An adversary may rely upon specific actions by a user in order to gain execution. Users may be subjected to social engineering to get them to execute malicious code by, for example, opening a malicious document file or link. These user actions will typically be observed as follow-on behavior from forms of [Phishing](#).

While [User Execution](#) frequently occurs shortly after Initial Access it may occur at other phases of an intrusion, such as when an adversary places a file in a shared directory or on a user's desktop hoping that a user will

click on it. This activity may also be seen shortly after [Internal Spearphishing](#).

Adversaries may also deceive users into performing actions such as:

- Enabling [Remote Access Tools](#), allowing direct control of the system to the adversary
- Running malicious JavaScript in their browser, allowing adversaries to [Steal Web Session Cookies](#)(Citation: Talos Roblox Scam 2023)(Citation: Krebs Discord Bookmarks 2023)
- Downloading and executing malware for [User Execution](#)
- Coerceing users to copy, paste, and execute malicious code manually(Citation: Reliaquest-execution)
(Citation: proofpoint-selfpwn)

For example, tech support scams can be facilitated through [Phishing](#), vishing, or various forms of user interaction. Adversaries can use a combination of these methods, such as spoofing and promoting toll-free numbers or call centers that are used to direct victims to malicious websites, to deliver and execute payloads containing malware or [Remote Access Tools](#).(Citation: Telephone Attack Delivery)

Digital Certificates - T1588.004

Adversaries may buy and/or steal SSL/TLS certificates that can be used during targeting. SSL/TLS certificates are designed to instill trust. They include information about the key, information about its owner's identity, and the digital signature of an entity that has verified the certificate's contents are correct. If the signature is valid, and the person examining the certificate trusts the signer, then they know they can use that key to communicate with its owner.

Adversaries may purchase or steal SSL/TLS certificates to further their operations, such as encrypting C2 traffic (ex: [Asymmetric Cryptography](#) with [Web Protocols](#)) or even enabling [Adversary-in-the-Middle](#) if the certificate is trusted or otherwise added to the root of trust (i.e. [Install Root Certificate](#)). The purchase of digital certificates may be done using a front organization or using information stolen from a previously compromised entity that allows the adversary to validate to a certificate provider as that entity. Adversaries may also steal certificate materials directly from a compromised third-party, including from certificate authorities.(Citation: DiginotarCompromise) Adversaries may register or hijack domains that they will later purchase an SSL/TLS certificate for.

Certificate authorities exist that allow adversaries to acquire SSL/TLS certificates, such as domain validation certificates, for free.(Citation: Let's Encrypt FAQ)

After obtaining a digital certificate, an adversary may then install that certificate (see [Install Digital Certificate](#)) on infrastructure under their control.

PowerShell - T1059.001

Adversaries may abuse PowerShell commands and scripts for execution. PowerShell is a powerful interactive command-line interface and scripting environment included in the Windows operating system.(Citation: TechNet PowerShell) Adversaries can use PowerShell to perform a number of actions, including discovery of information and execution of code. Examples include the [Start-Process](#) cmdlet which can be used to run an executable and the [Invoke-Command](#) cmdlet which runs a command locally or on a remote computer (though administrator permissions are required to use PowerShell to connect to remote systems).

PowerShell may also be used to download and run executables from the Internet, which can be executed from disk or in memory without touching disk.

A number of PowerShell-based offensive testing tools are available, including [Empire](#), [PowerSploit](#), [PoshC2](#), and PSAttack.(Citation: Github PSAttack)

PowerShell commands/scripts can also be executed without directly invoking the `powershell.exe` binary through interfaces to PowerShell's underlying `System.Management.Automation` assembly DLL exposed through the .NET framework and Windows Common Language Interface (CLI).(Citation: Sixdub PowerPick Jan 2016)(Citation: SilentBreak Offensive PS Dec 2015)(Citation: Microsoft PSfromCsharp APR 2014)

Application Layer Protocol - T1071

Adversaries may communicate using OSI application layer protocols to avoid detection/network filtering by blending in with existing traffic. Commands to the remote system, and often the results of those commands, will be embedded within the protocol traffic between the client and server.

Adversaries may utilize many different protocols, including those used for web browsing, transferring files, electronic mail, DNS, or publishing/subscribing. For connections that occur internally within an enclave (such as those between a proxy or pivot node and other nodes), commonly used protocols are SMB, SSH, or RDP. (Citation: Mandiant APT29 Eye Spy Email Nov 22)

Exploitation for Privilege Escalation - T1068

Adversaries may exploit software vulnerabilities in an attempt to elevate privileges. Exploitation of a software vulnerability occurs when an adversary takes advantage of a programming error in a program, service, or within the operating system software or kernel itself to execute adversary-controlled code. Security constructs such as permission levels will often hinder access to information and use of certain techniques, so adversaries will likely need to perform privilege escalation to include use of software exploitation to circumvent those restrictions.

When initially gaining access to a system, an adversary may be operating within a lower privileged process which will prevent them from accessing certain resources on the system. Vulnerabilities may exist, usually in operating system components and software commonly running at higher permissions, that can be exploited to gain higher levels of access on the system. This could enable someone to move from unprivileged or user level permissions to SYSTEM or root permissions depending on the component that is vulnerable. This could also enable an adversary to move from a virtualized environment, such as within a virtual machine or container, onto the underlying host. This may be a necessary step for an adversary compromising an endpoint system that has been properly configured and limits other privilege escalation methods.

Adversaries may bring a signed vulnerable driver onto a compromised machine so that they can exploit the vulnerability to execute code in kernel mode. This process is sometimes referred to as Bring Your Own Vulnerable Driver (BYOVD).(Citation: ESET InvisiMole June 2020)(Citation: Unit42 AcidBox June 2020)

Adversaries may include the vulnerable driver with files delivered during Initial Access or download it to a compromised system via [Ingress Tool Transfer](#) or [Lateral Tool Transfer](#).

Deobfuscate/Decode Files or Information - T1140

Adversaries may use [Obfuscated Files or Information](#) to hide artifacts of an intrusion from analysis. They may require separate mechanisms to decode or deobfuscate that information depending on how they intend to use it. Methods for doing that include built-in functionality of malware or by using utilities present on the system.

One such example is the use of [certutil](#) to decode a remote access tool portable executable file that has been hidden inside a certificate file.(Citation: Malwarebytes Targeted Attack against Saudi Arabia) Another example is using the Windows [copy /b](#) or [type](#) command to reassemble binary fragments into a malicious payload.(Citation: Carbon Black Obfuscation Sept 2016)(Citation: Sentinel One Tainted Love 2023)

Sometimes a user's action may be required to open it for deobfuscation or decryption as part of [User Execution](#). The user may also be required to input a password to open a password protected compressed/encrypted file that was provided by the adversary.(Citation: Volexity PowerDuke November 2016)

Valid Accounts - T1078

Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion. Compromised credentials may be used to bypass access controls placed on various resources on systems within the network and may even be used for persistent access to remote systems and externally available services, such as VPNs, Outlook Web Access, network devices, and remote desktop.(Citation: volexity_0day_sophos_FW) Compromised credentials may also grant an adversary increased privilege to specific systems or access to restricted areas of the network. Adversaries may choose not to use malware or tools in conjunction with the legitimate access those credentials provide to make it harder to detect their presence.

In some cases, adversaries may abuse inactive accounts: for example, those belonging to individuals who are no longer part of an organization. Using these accounts may allow the adversary to evade detection, as the original account user will not be present to identify any anomalous activity taking place on their account.(Citation: CISA MFA PrintNightmare)

The overlap of permissions for local, domain, and cloud accounts across a network of systems is of concern because the adversary may be able to pivot across accounts and systems to reach a high level of access (i.e., domain or enterprise administrator) to bypass access controls set within the enterprise.(Citation: TechNet Credential Theft)

Virtual Private Server - T1583.003

Adversaries may rent Virtual Private Servers (VPSs) that can be used during targeting. There exist a variety of cloud service providers that will sell virtual machines/containers as a service. By utilizing a VPS, adversaries can make it difficult to physically tie back operations to them. The use of cloud infrastructure can also make it easier for adversaries to rapidly provision, modify, and shut down their infrastructure.

Acquiring a VPS for use in later stages of the adversary lifecycle, such as Command and Control, can allow adversaries to benefit from the ubiquity and trust associated with higher reputation cloud service providers. Adversaries may also acquire infrastructure from VPS service providers that are known for renting VPSs with minimal registration information, allowing for more anonymous acquisitions of infrastructure.(Citation: TrendmicroHideoutsLease)

Command and Scripting Interpreter - T1059

Adversaries may abuse command and script interpreters to execute commands, scripts, or binaries. These interfaces and languages provide ways of interacting with computer systems and are a common feature across many different platforms. Most systems come with some built-in command-line interface and scripting capabilities, for example, macOS and Linux distributions include some flavor of [Unix Shell](#) while Windows installations include the [Windows Command Shell](#) and [PowerShell](#).

There are also cross-platform interpreters such as [Python](#), as well as those commonly associated with client applications such as [JavaScript](#) and [Visual Basic](#).

Adversaries may abuse these technologies in various ways as a means of executing arbitrary commands. Commands and scripts can be embedded in [Initial Access](#) payloads delivered to victims as lure documents or as secondary payloads downloaded from an existing C2. Adversaries may also execute commands through interactive terminals/shells, as well as utilize various [Remote Services](#) in order to achieve remote Execution. (Citation: Powershell Remote Commands)(Citation: Cisco IOS Software Integrity Assurance - Command History)(Citation: Remote Shell Execution in Python)

Command and Scripting Interpreter - T1059

Adversaries may abuse command and script interpreters to execute commands, scripts, or binaries. These interfaces and languages provide ways of interacting with computer systems and are a common feature across many different platforms. Most systems come with some built-in command-line interface and scripting capabilities, for example, macOS and Linux distributions include some flavor of [Unix Shell](#) while Windows installations include the [Windows Command Shell](#) and [PowerShell](#).

There are also cross-platform interpreters such as [Python](#), as well as those commonly associated with client applications such as [JavaScript](#) and [Visual Basic](#).

Adversaries may abuse these technologies in various ways as a means of executing arbitrary commands. Commands and scripts can be embedded in [Initial Access](#) payloads delivered to victims as lure documents or as secondary payloads downloaded from an existing C2. Adversaries may also execute commands through interactive terminals/shells, as well as utilize various [Remote Services](#) in order to achieve remote Execution. (Citation: Powershell Remote Commands)(Citation: Cisco IOS Software Integrity Assurance - Command History)(Citation: Remote Shell Execution in Python)

Boot or Logon Autostart Execution - T1547

Adversaries may configure system settings to automatically execute a program during system boot or logon to maintain persistence or gain higher-level privileges on compromised systems. Operating systems may have mechanisms for automatically running a program on system boot or account logon.(Citation: Microsoft Run Key)(Citation: MSDN Authentication Packages)(Citation: Microsoft TimeProvider)(Citation: Cylance Reg Persistence Sept 2013)(Citation: Linux Kernel Programming) These mechanisms may include automatically executing programs that are placed in specially designated directories or are referenced by repositories that store configuration information, such as the Windows Registry. An adversary may achieve the same goal by modifying or extending features of the kernel.

Since some boot or logon autostart programs run with higher privileges, an adversary may leverage these to elevate privileges.

Clipboard Data - T1115

Adversaries may collect data stored in the clipboard from users copying information within or between applications.

For example, on Windows adversaries can access clipboard data by using `clip.exe` or `Get-Clipboard`. (Citation: MSDN Clipboard)(Citation: clip_win_server)(Citation: CISA_AA21_200B) Additionally, adversaries may monitor then replace users' clipboard with their data (e.g., [Transmitted Data Manipulation](#)).(Citation: mining_ruby_reversinglabs)

macOS and Linux also have commands, such as `pbpaste`, to grab clipboard contents.(Citation: Operating with EmPyre)

Malicious File - T1204.002

An adversary may rely upon a user opening a malicious file in order to gain execution. Users may be subjected to social engineering to get them to open a file that will lead to code execution. This user action will typically be observed as follow-on behavior from [Spearphishing Attachment](#). Adversaries may use several types of files that require a user to execute them, including .doc, .pdf, .xls, .rtf, .scr, .exe, .lnk, .pif, .cpl, .reg, and .iso.(Citation: Mandiant Trojanized Windows 10)

Adversaries may employ various forms of [Masquerading](#) and [Obfuscated Files or Information](#) to increase the likelihood that a user will open and successfully execute a malicious file. These methods may include using a familiar naming convention and/or password protecting the file and supplying instructions to a user on how to open it.(Citation: Password Protected Word Docs)

While [Malicious File](#) frequently occurs shortly after Initial Access it may occur at other phases of an intrusion, such as when an adversary places a file in a shared directory or on a user's desktop hoping that a user will click on it. This activity may also be seen shortly after [Internal Spearphishing](#).

Inhibit System Recovery - T1490

Adversaries may delete or remove built-in data and turn off services designed to aid in the recovery of a corrupted system to prevent recovery.(Citation: Talos Olympic Destroyer 2018)(Citation: FireEye WannaCry 2017) This may deny access to available backups and recovery options.

Operating systems may contain features that can help fix corrupted systems, such as a backup catalog, volume shadow copies, and automatic repair features. Adversaries may disable or delete system recovery features to augment the effects of [Data Destruction](#) and [Data Encrypted for Impact](#).(Citation: Talos Olympic Destroyer 2018)(Citation: FireEye WannaCry 2017) Furthermore, adversaries may disable recovery notifications, then corrupt backups.(Citation: disable_notif_synology_ransom)

A number of native Windows utilities have been used by adversaries to disable or delete system recovery features:

- `vssadmin.exe` can be used to delete all volume shadow copies on a system - `vssadmin.exe delete shadows /all /quiet`
- [Windows Management Instrumentation](#) can be used to delete volume shadow copies - `wmic shadowcopy delete`
- `wbadmin.exe` can be used to delete the Windows Backup Catalog - `wbadmin.exe delete catalog - quiet`

- `bcdedit.exe` can be used to disable automatic Windows recovery features by modifying boot configuration data - `bcdedit.exe /set {default} bootstatuspolicy ignoreallfailures & bcdedit /set {default} recoveryenabled no`
- `REAgentC.exe` can be used to disable Windows Recovery Environment (WinRE) repair/recovery options of an infected system
- `diskshadow.exe` can be used to delete all volume shadow copies on a system - `diskshadow delete shadows all` (Citation: Diskshadow) (Citation: Crytox Ransomware)

On network devices, adversaries may leverage [Disk Wipe](#) to delete backup firmware images and reformat the file system, then [System Shutdown/Reboot](#) to reload the device. Together this activity may leave network devices completely inoperable and inhibit recovery operations.

On ESXi servers, adversaries may delete or encrypt snapshots of virtual machines to support [Data Encrypted for Impact](#), preventing them from being leveraged as backups (e.g., via `vim-cmd vmsvc/snapshot.removeall`). (Citation: Cybereason)

Adversaries may also delete "online" backups that are connected to their network – whether via network storage media or through folders that sync to cloud services. (Citation: ZDNet Ransomware Backups 2020) In cloud environments, adversaries may disable versioning and backup policies and delete snapshots, database backups, machine images, and prior versions of objects designed to be used in disaster recovery scenarios. (Citation: Dark Reading Code Spaces Cyber Attack) (Citation: Rhino Security Labs AWS S3 Ransomware)

OS Credential Dumping - T1003

Adversaries may attempt to dump credentials to obtain account login and credential material, normally in the form of a hash or a clear text password. Credentials can be obtained from OS caches, memory, or structures. (Citation: Brining MimiKatz to Unix) Credentials can then be used to perform [Lateral Movement](#) and access restricted information.

Several of the tools mentioned in associated sub-techniques may be used by both adversaries and professional security testers. Additional custom tools likely exist as well.

Obtain Capabilities - T1588

Adversaries may buy and/or steal capabilities that can be used during targeting. Rather than developing their own capabilities in-house, adversaries may purchase, freely download, or steal them. Activities may include the acquisition of malware, software (including licenses), exploits, certificates, and information relating to vulnerabilities. Adversaries may obtain capabilities to support their operations throughout numerous phases of the adversary lifecycle.

In addition to downloading free malware, software, and exploits from the internet, adversaries may purchase these capabilities from third-party entities. Third-party entities can include technology companies that specialize in malware and exploits, criminal marketplaces, or from individuals. (Citation: NationsBuying) (Citation: PegasusCitizenLab)

In addition to purchasing capabilities, adversaries may steal capabilities from third-party entities (including other adversaries). This can include stealing software licenses, malware, SSL/TLS and code-signing certificates, or raiding closed databases of vulnerabilities or exploits. (Citation: DiginotarCompromise)

Proxy - T1090

Adversaries may use a connection proxy to direct network traffic between systems or act as an intermediary for network communications to a command and control server to avoid direct connections to their infrastructure. Many tools exist that enable traffic redirection through proxies or port redirection, including [HTRAN](#), [ZXProxy](#), and [ZXPortMap](#). (Citation: Trend Micro APT Attack Tools) Adversaries use these types of proxies to manage command and control communications, reduce the number of simultaneous outbound network connections, provide resiliency in the face of connection loss, or to ride over existing trusted communications paths between victims to avoid suspicion. Adversaries may chain together multiple proxies to further disguise the source of malicious traffic.

Adversaries can also take advantage of routing schemes in Content Delivery Networks (CDNs) to proxy command and control traffic.

Server - T1583.004

Adversaries may buy, lease, rent, or obtain physical servers that can be used during targeting. Use of servers allows an adversary to stage, launch, and execute an operation. During post-compromise activity, adversaries may utilize servers for various tasks, such as watering hole operations in [Drive-by Compromise](#), enabling [Phishing](#) operations, or facilitating [Command and Control](#). Instead of compromising a third-party [Server](#) or renting a [Virtual Private Server](#), adversaries may opt to configure and run their own servers in support of operations. Free trial periods of cloud servers may also be abused.(Citation: Free Trial PurpleUrchin)(Citation: Freejacked)

Adversaries may only need a lightweight setup if most of their activities will take place using online infrastructure. Or, they may need to build extensive infrastructure if they want to test, communicate, and control other aspects of their activities on their own systems.(Citation: NYTStuxnet)

Malicious Link - T1204.001

An adversary may rely upon a user clicking a malicious link in order to gain execution. Users may be subjected to social engineering to get them to click on a link that will lead to code execution. This user action will typically be observed as follow-on behavior from [Spearphishing Link](#). Clicking on a link may also lead to other execution techniques such as exploitation of a browser or application vulnerability via [Exploitation for Client Execution](#). Links may also lead users to download files that require execution via [Malicious File](#).

Create or Modify System Process - T1543

Adversaries may create or modify system-level processes to repeatedly execute malicious payloads as part of persistence. When operating systems boot up, they can start processes that perform background system functions. On Windows and Linux, these system processes are referred to as services.(Citation: TechNet Services) On macOS, launchd processes known as [Launch Daemon](#) and [Launch Agent](#) are run to finish system initialization and load user specific parameters.(Citation: AppleDocs Launch Agent Daemons)

Adversaries may install new services, daemons, or agents that can be configured to execute at startup or a repeatable interval in order to establish persistence. Similarly, adversaries may modify existing services, daemons, or agents to achieve the same effect.

Services, daemons, or agents may be created with administrator privileges but executed under root/SYSTEM privileges. Adversaries may leverage this functionality to create or modify system processes in order to escalate privileges.(Citation: OSX Malware Detection)

Phishing - T1566

Adversaries may send phishing messages to gain access to victim systems. All forms of phishing are electronically delivered social engineering. Phishing can be targeted, known as spearphishing. In spearphishing, a specific individual, company, or industry will be targeted by the adversary. More generally, adversaries can conduct non-targeted phishing, such as in mass malware spam campaigns.

Adversaries may send victims emails containing malicious attachments or links, typically to execute malicious code on victim systems. Phishing may also be conducted via third-party services, like social media platforms. Phishing may also involve social engineering techniques, such as posing as a trusted source, as well as evasive techniques such as removing or manipulating emails or metadata/headers from compromised accounts being abused to send messages (e.g., [Email Hiding Rules](#)).(Citation: Microsoft OAuth Spam 2022)(Citation: Palo Alto Unit 42 VBA Infostealer 2014) Another way to accomplish this is by [Email Spoofing](#)(Citation: Proofpoint-spoof) the identity of the sender, which can be used to fool both the human recipient as well as automated security tools.(Citation: cyberproof-double-bounce) or by including the intended target as a party to an existing email thread that includes malicious files or links (i.e., "thread hijacking").(Citation: phishing-krebs)

Victims may also receive phishing messages that instruct them to call a phone number where they are directed to visit a malicious URL, download malware,(Citation: sygnia Luna Month)(Citation: CISA Remote Monitoring and Management Software) or install adversary-accessible remote management tools onto their computer (i.e., [User Execution](#)).(Citation: Unit42 Luna Moth)

Data Encrypted for Impact - T1486

Adversaries may encrypt data on target systems or on large numbers of systems in a network to interrupt availability to system and network resources. They can attempt to render stored data inaccessible by encrypting files or data on local and remote drives and withholding access to a decryption key. This may be done in order to extract monetary compensation from a victim in exchange for decryption or a decryption key (ransomware) or to render data permanently inaccessible in cases where the key is not saved or transmitted. (Citation: US-CERT Ransomware 2016)(Citation: FireEye WannaCry 2017)(Citation: US-CERT NotPetya 2017) (Citation: US-CERT SamSam 2018)

In the case of ransomware, it is typical that common user files like Office documents, PDFs, images, videos, audio, text, and source code files will be encrypted (and often renamed and/or tagged with specific file markers). Adversaries may need to first employ other behaviors, such as [File and Directory Permissions Modification](#) or [System Shutdown/Reboot](#), in order to unlock and/or gain access to manipulate these files. (Citation: CarbonBlack Conti July 2020) In some cases, adversaries may encrypt critical system files, disk partitions, and the MBR.(Citation: US-CERT NotPetya 2017) Adversaries may also encrypt virtual machines hosted on ESXi or other hypervisors.(Citation: CrowdStrike Hypervisor Jackpotting Pt 2 2021)

To maximize impact on the target organization, malware designed for encrypting data may have worm-like features to propagate across a network by leveraging other attack techniques like [Valid Accounts](#), [OS Credential Dumping](#), and [SMB/Windows Admin Shares](#).(Citation: FireEye WannaCry 2017)(Citation: US-CERT NotPetya 2017) Encryption malware may also leverage [Internal Defacement](#), such as changing victim

wallpapers or ESXi server login messages, or otherwise intimidate victims by sending ransom notes or other messages to connected printers (known as "print bombing").(Citation: NHS Digital Egregor Nov 2020)
(Citation: Varonis)

In cloud environments, storage objects within compromised accounts may also be encrypted.(Citation: Rhino S3 Ransomware Part 1) For example, in AWS environments, adversaries may leverage services such as AWS's Server-Side Encryption with Customer Provided Keys (SSE-C) to encrypt data.(Citation: Halcyon AWS Ransomware 2025)

Acquire Infrastructure - T1583

Adversaries may buy, lease, rent, or obtain infrastructure that can be used during targeting. A wide variety of infrastructure exists for hosting and orchestrating adversary operations. Infrastructure solutions include physical or cloud servers, domains, and third-party web services.(Citation: TrendmicroHideoutsLease) Some infrastructure providers offer free trial periods, enabling infrastructure acquisition at limited to no cost. (Citation: Free Trial PurpleUrchin) Additionally, botnets are available for rent or purchase.

Use of these infrastructure solutions allows adversaries to stage, launch, and execute operations. Solutions may help adversary operations blend in with traffic that is seen as normal, such as contacting third-party web services or acquiring infrastructure to support [Proxy](#), including from residential proxy services.(Citation: amnesty_nso_pegasus)(Citation: FBI Proxies Credential Stuffing)(Citation: Mandiant APT29 Microsoft 365 2022) Depending on the implementation, adversaries may use infrastructure that makes it difficult to physically tie back to them as well as utilize infrastructure that can be rapidly provisioned, modified, and shut down.

Exfiltration Over C2 Channel - T1041

Adversaries may steal data by exfiltrating it over an existing command and control channel. Stolen data is encoded into the normal communications channel using the same protocol as command and control communications.